

What each trust claim actually proves

A compliance badge is a claim about a defined scope and a time window, not a guarantee about your client's data. Before you upload a floor plan or survey to a cloud tool, read what each claim covers, and what it deliberately does not.

THE ONE RULE **Read the scope, not the logo.** A vendor can be "certified" for its corporate IT while the specific product you use sits outside the certified scope. The scope line is the whole ballgame.

TRUST CLAIM	WHAT IT ACTUALLY PROVES	WHAT IT DOES NOT PROVE	WHAT TO ASK FOR
ISO/IEC 27001 2022 · accredited certificate Certificate	A working Information Security Management System over a defined scope - risk assessment done, Annex A controls selected, and a mandatory Statement of Applicability documenting which apply and why.	That any specific control you care about is in place (an org does not implement all 93), or that the product you use falls inside the certified scope.	The scope statement , the accredited certification body, and the registrar / certificate number - confirm it is live, not lapsed.
SOC 2 Type 1 attestation · snapshot on a date Attestation	That the controls were suitably designed at a single point in time . A starting posture - often the first report a young vendor produces.	That the controls actually operated over time. A design snapshot is not evidence of day-to-day operation.	Whether a Type 2 exists yet, the report date, and which Trust Services Criteria are in scope.
SOC 2 Type 2 attestation · tested over 6-12 mo Attestation	Controls designed and operating effectively over a period (typically 6–12 months) - the auditor tested that they actually worked. The SOC 2 that carries weight.	Coverage beyond the named systems and criteria . Only Security is mandatory; Availability, Confidentiality, and Privacy appear only if the vendor included them.	The report under NDA ; a clean (unqualified) opinion ; that Confidentiality (and Privacy, if PII) is in scope; freshness within ~12 months or a bridge letter.
GDPR / EU residency a law, not a badge · self-asserted Self-asserted	By itself, nothing . "GDPR compliant" is a self-asserted statement of conformity - there is no official stamp behind most vendor claims.	That data is safe, or that "EU-region hosting" solves it. Residency (where bytes sit) is not sovereignty (whose laws reach the data) - a US-headquartered vendor can face CLOUD Act reach even on EU servers.	Where data is hosted , the transfer mechanism (DPF self-cert / SCCs / BCRs), and whether EU-region processing is an option - then route to the privacy officer.